

令和5年秋 応用情報 午後問1【情報セキュリティ】小南解題

一、整体背景梳理

-  业务背景与历史教训：
 - K社是一家 IT 产品批发商，对接 300 家销售店。
 - 8 年前，有员工错把包含特定销售店促销奖励金的策划案发给了所有销售店，造成严重信息泄露事故。
 - 为解决误发送，K社引入了“附件压缩服务器”，将附件自动转为带一次性密码（DPW）的 ZIP 压缩包。
-  日本独特的“PPAP”危机：
 - **PPAP 流程**：先发带加密 ZIP 的邮件（本文メール），紧接着用相同邮件系统发一封包含解密密码的邮件（PWメール）。
 - **全面弃用趋势**：日本政府及同业逐步宣布“废除 PPAP”，K社安全领导 L 主任展开风险排查：
 - **缺陷 1（误操作）**：员工发错第一封主邮件后，根本不检查，习惯性把密码邮件也直接群发给了错的人。
 - **缺陷 2（链路被劫）**：两封邮件走同一个邮件系统。如果通信线路被黑客监听，黑客能同时拿到压缩包和密码，加密形同虚设。
-  终极解法：引入 S/MIME 邮件加密与签名：
 - 为彻底解决盗听与伪造，K社决定导入基于 PKI 体系的 **S/MIME** 协议，实现邮件全流程加密与防篡改。

二、逐题深度解析

設問 1：PPAP 现行流程的漏洞与运营改进

(1) 下划线①：不核对地址就发密码邮件，会导致什么后果？（40字以内）

- 参考答案：本文メールを誤送信すると，DPWも誤送信した相手に届いてしまう（31字）
 - （主邮件发错人时，密码也会直接送到发错的对象手里）
- 逻辑拆解：

- PPAP 唯一的理论优势原本是“分两封发，给员工第二次核对地址的机会”。
- 但如果员工养成习惯不看地址顺手就发，一旦第一封主邮件发错了，第二封包含密码的邮件（DPW）也会毫不犹豫地**送到错误接收人手中**。收错件的人直接拿到密码开包，导致内部机密信息彻底泄露。

(2) 下划线②：针对“相同通信链路被盗听”风险，运营层面的改进措施？（30字以内）

- **参考答案：** DPWを，電話や携帯メールなど異なった手段で伝える （25字）
- **逻辑拆解：**
 - **审题红线：**题目限定要求“运营层面（運用上）的改进”，而非技术层面的升级（如引入 S/MIME）。
 - **原根源：**主邮件与密码邮件走同一条 Email 链路，被窃听就会被“一锅端”。
 - **运营解法：**密码绝不能再走邮件！必须通过不同的通信渠道/手段（电话、SMS手机短信、微信/Teams聊天工具等）告知接收方，打破单一链路被盗听的风险。

設問 2：S/MIME 规范与公私钥机制

(1) 下划线③：在表1、表2中，哪个步骤检测出了“邮件篡改（改ざん）”？

- **参考答案：** 1.6
- **逻辑拆解：**
 - **数字签名防篡改原理：**
 1. 发送方对正文生成 Hash X，用私钥加密形成签名。
 2. 接收方收到后，用发送方公钥解密出 Hash X；同时对收到的正文重新计算生成 Hash Y。
 3. **对比 Hash X 与 Hash Y 是否一致。**如果一致，说明中途没被篡改；如果不一致，则触发篡改告警。
 - 查看表1，步骤 **1.6** 正是执行“对比验证 Hash 值”的关键步骤。

(2) 填空 a, b, c, d：公钥与私钥配对（四选一）

- **参考答案：**
 - **a：** 力 （送信者の秘密鍵 / 发送方私钥）

- **b** : オ (送信者の公開鍵 / 发送方公钥)
- **c** : ウ (受信者の公開鍵 / 接收方公钥)
- **d** : エ (受信者の秘密鍵 / 接收方私钥)
- 逻辑拆解 :
 - **电子签名 (防伪造/防篡改)** : 用发送方的私钥 (力) 加密 Hash 值生成签名 ; 接收方用发送方的公钥 (才) 解密验证签名。
 - **正文加密 (混合加密体系)** : 发送方用接收方的公钥 (ウ) 加密对称共通密钥 ; 接收方收到后, 用自己的私钥 (工) 解密拿到共通密钥。

(3) 下划线④ : 正文加密采用“共通密钥 (对称加密)”而非“公开密钥”的原因 ? (20字以内)

- 参考答案 : 暗号化と復号の処理速度が速いから (16字)
 - (別解 : 暗号化と復号の計算量が少ないから / 16字)
- 逻辑拆解 :
 - **非对称加密 (公钥/私钥)** : 安全性高, 但数学计算极其复杂, 加解密大文件 (如邮件正文、大附件) 速度极慢。
 - **对称加密 (共通密钥)** : 算法简单高效, 加解密速度飞快。
 - **混合加密 (Hybrid Encryption)** : 用非对称加密来安全传输轻量级的“共通密钥”, 用共通密钥来高速加解密海量的“邮件正文/附件”, 完美兼顾安全与处理速度 (処理速度が速い)。

設問 3 : 数字证书的权威性验证

- 参考答案 : ア (CAの公開鍵 / 认证机构的公钥)
- 逻辑拆解 :
 - 数字证书 (電子証明書) 本质上是权威认证机构 (CA) 给发送方颁发的“网络身份证”, 上面盖有 **CA 的数字签名**。
 - 当客户端收到证书时, 为了确认这个证书确实是合法 CA 颁发的、没有被中间人篡改伪造, 必须使用 **CA 的公钥 (CAの公開鍵)** 来解密并验证 CA 的数字签名。



三、核心考点速查

考察维度	考点核心	原理要点
✖ 传统 PPAP	双邮件同链路缺陷	同一邮件系统发密码无法防盗听；不核对地址发密码无法防误发送。
✍ 数字签名	发送方私钥加密 $\rightarrow$ 发送方公钥解密	证明身份（防冒充）、验证完整性（比对 Hash 值防篡改）。
🔒 混合加密	接收方公钥传密钥 $\rightarrow$ 共通密钥加解密正文	共通密钥处理大数据量速度飞快，解决非对称加密计算性能瓶颈。
📄 数字证书	CA 公钥验签	验证证书合法性必须使用颁发机构 CA 的公钥来校验其数字签名。